UNIVERSIDAD PERUANA CAYETANO HEREDIA

FACULTAD DE CIENCIAS E INGENIERÍA

LABORATORIO 12

SISTEMAS OPERATIVOS



Grupo 4

Integrantes:

Hernandez Lopez, Justin Brayton

Rebatta Jeri, Patricia del Pilar

Medina Rojas, Martha Sofía

Vega Sanchez. Jimena Natalia

Profesor:
Roberto Eduardo Burga Montañez

Actividad 1: Análisis de Amenazas de Seguridad

Objetivo: Identificar amenazas y objetivos de seguridad en un entorno organizacional.

Modalidad: Grupal

Instrucciones:

1. Analicen el caso de una empresa que almacena información confidencial de clientes.
2. Identifiquen al menos:
    - 5 amenazas potenciales.
    - Los activos de información afectados.
    - Los objetivos de seguridad comprometidos (confidencialidad, integridad y disponibilidad).
3. Elaboren una matriz de riesgos.

Producto esperado:

Amenaza	Activo afectado	Impacto	Objetivo comprometido
Malware	Base de datos	Alto	Integridad

Tiempo: 30 minutos.

Caso de la empresa

Una empresa almacena información confidencial de sus clientes, como nombres, apellidos, números de DNI, direcciones, teléfonos, correos electrónicos y datos de pago Esta información se encuentra guardada en una base de datos y es utilizada por los empleados para realizar sus actividades.

Identificación de amenazas potenciales

- **Malware o ransomware:** programa malicioso que puede dañar, cifrar o robar información
- **Phishing:** mensajes o correos falsos que engañan a los empleados para obtener sus contraseñas
- **Acceso no autorizado:** ingreso de personas sin permisos a los sistemas o a la base de datos
- **Fallo del servidor:** problemas técnicos que impiden acceder a la información
- Error humano: eliminación o modificación accidental de datos por parte de un empleado.
- **Ataque DDoS:** saturación de los servidores que impide el funcionamiento normal de los servicios.

Matriz de riesgos:

Amenaza	Activo afectado	Impacto	Objetivo Comprometido
Malware o ransomware	Base de datos y servidores	Alto: puede cifrar archivos y provocar la pérdida de acceso a la información	Integridad y disponibilidad
Phishing	Cuentas de usuarios y datos de clientes	Alto: puede permitir el robo de contraseñas y la filtración de información confidencial	Confidencialidad
Acceso no autorizado	Base de datos de clientes	Alto: puede provocar la exposición o el robo de datos personales.	Confidencialidad
Fallo del servidor	Servidores y sistemas informáticos	Alto: impide acceder a la información y utilizar los servicios	Disponibilidad
Error humano	Bases de datos y registros de clientes	Medio: puede ocasionar la eliminación o modificación incorrecta de datos.	Integridad
Ataque DDos	Servidores y red informática	Alto: interrumpe los servicios e impide el acceso de los usuarios	Disponibilidad

Medidas de prevención

- **Malware o ransomware:** utilizar antivirus y realizar copias de seguridad
- **Phishing:** capacitar a los empleados para reconocer correos fraudulentos
- **Acceso no autorizado:** establecer contraseñas seguras y permisos de acceso.
- **Fallo del servidor:** realizar mantenimiento preventivo y contar con copias de seguridad.
- **Error humano:** capacitar al personal y verificar los cambios en la información
- **Ataques DDos:** implementar sistemas de protección y supervisar el tráfico de la red.

Actividad 2: Detección de Accesos No Autorizados

Objetivo: Reconocer diferentes tipos de ataques informáticos.

Modalidad: Individual

Instrucciones:

Clasifique cada situación según corresponda:

Situación	Tipo de ataque
Un usuario prueba miles de contraseñas automáticamente	**Ataque de fuerza bruta**
Se recibe un correo falso solicitando credenciales	**Phishing**
Un programa captura las teclas pulsadas	**Keylogger**
Se interceptan datos durante una transmisión	**Ataque Man-in-the-Middle**

Preguntas de reflexión :

¿Qué ataque considera más peligroso para una universidad?

Considero que el **phishing** puede ser uno de los ataques más peligrosos para una universidad, porque puede engañar a estudiantes, profesores y trabajadores para que entreguen sus contraseñas. Con una cuenta comprometida, un atacante podría acceder a información académica, datos personales, correos institucionales o incluso otros sistemas de la universidad.

¿Qué medidas de seguridad recomendaría para prevenir estos ataques?

- Utilizar contraseñas seguras y diferentes para cada cuenta.
- Activar la autenticación multifactor (MFA).
- Capacitar a estudiantes y trabajadores para reconocer correos de phishing.
- Utilizar antivirus y sistemas de detección de malware para prevenir keyloggers.
- Mantener los sistemas y programas actualizados.
- Utilizar cifrado HTTPS/VPN para proteger los datos durante las transmisiones.
- Implementar bloqueo temporal de cuentas después de varios intentos fallidos de inicio de sesión.

Actividad 3: Diseño de una Política de Seguridad

Objetivo: Aplicar conceptos de políticas y mecanismos de seguridad.

Modalidad: Grupal

Instrucciones:

Diseñen una política de seguridad para el laboratorio de informática de una universidad.

Debe incluir:

• Gestión de contraseñas.
• Uso de dispositivos USB.
• Acceso a internet.
• Respaldo de información.
• Sanciones por incumplimiento.

Producto esperado:

Documento de máximo 2 páginas.

Diseño de una política de seguridad para el laboratorio de Informática

Establecer controles técnicos, administrativos y legales (ISO/IEC 27000, 27002, 27032 y NIST) para preservar la Confidencialidad, Integridad y Disponibilidad (CID) en el Laboratorio de Informática Universitario bajo el modelo IAAA (Identificación, Autenticación, Autorización y Rendición de cuentas).

1. Control de Credenciales y Autenticación de Usuarios

- Asignar cuentas individuales vinculadas al sistema institucional SSO, aplicando un esquema de mínimos privilegios según la función del estudiante, docente o personal administrativo.
- Exigir claves complejas con un mínimo de 12 caracteres, integrando letras mayúsculas, minúsculas, números y símbolos. Queda prohibida la inclusión de datos personales, secuencias de teclado o anotar credenciales en lugares visibles.
- Exigir autenticación de doble factor (2FA) para perfiles administrativos y acceso a servidores, asegurando el bloqueo de sesión por inactividad tras transcurrir 5 minutos.

2. Regulación de Almacenamiento Removible USB

- Inhabilitar la reproducción automática en los puertos del sistema operativo para neutralizar vectores de transmisión de amenazas o ransomware.
- Analizar automáticamente cualquier unidad de memoria con el software antivirus previo a su apertura, restringiendo formatos comprimidos o accesos directos no verificados.
- Restringir los permisos de instalación de ejecutables a usuarios estándar e implementar controles DLP para resguardar la información de la institución.

3. Restricciones de Red y Navegación Web

- Filtrar el tráfico mediante cortafuegos institucionales, bloqueando enlaces de phishing, descargas peligrosas y conexiones entre pares no autorizadas.
- Exigir conexiones seguras cifradas HTTPS y canales VPN para el envío o recepción de datos en la plataforma institucional.
- Aislar la red local del laboratorio informático en una subred independiente, manteniendo la supervisión constante frente a posibles ataques o saturaciones del servicio.

4. Copias de Seguridad y Resguardo Documental

- Programar respaldos periódicos mediante la combinación de copias diarias incrementales y respaldos completos cada semana para prevenir pérdidas.
- Garantizar la redundancia de datos mediante arreglos de discos locales y sincronizar duplicados cifrados en el servicio en la nube corporativo.
- Verificar semestralmente los procedimientos de restauración de carpetas y asegurar la eliminación definitiva de soportes físicos o digitales en desuso.

5. Régimen de Sanciones y Monitoreo de Registro

Las acciones efectuadas en la red se- registrarán en bitácoras de auditoría asociadas a cada usuario, aplicándose las medidas disciplinarias respectivas en caso de infracción:

Nivel de Falta	Incumplimientos Tipificados	Sanción y Medida Correctiva
Falta Leve	• Dejar sesión abierta sin bloqueo al retirarse. • Conectar memorias USB sin escaneo previo. • Intentar acceder a sitios web recreativos bloqueados.	• Amonestación escrita registrada en el laboratorio. • Cierre forzoso de sesión y cambio obligatorio de clave.
Falta Grave	• Compartir contraseñas o usar cuentas ajenas. • Intentar vulnerar permisos para instalar software no aprobado o desactivar el antivirus/firewall.	• Suspensión temporal de la cuenta y del acceso al laboratorio (15 a 30 días). • Reporte a Dirección de Escuela y anulación de práctica.
Falta Muy Grave	• Ejecutar ataques internos (fuerza bruta, keyloggers, phishing, DoS o malware/ransomware). • Extraer, alterar o destruir bases de datos o notas.	• Revocación definitiva de accesos y credenciales. • Proceso disciplinario universitario y denuncia legal por delitos informáticos.

Actividad 4: Taller de Autenticación y Validación

Objetivo: Comprender mecanismos de validación y autenticación.

Modalidad: Parejas

Instrucciones:

Investiguen y comparen:

1. Contraseña tradicional.
2. Doble factor de autenticación (2FA).
3. Biometría.
4. Tokens de seguridad.

Completen la siguiente tabla:

Método Nivel de seguridad Ventajas Desventajas

Discusión final:

¿Cuál método sería más adecuado para una entidad financiera?

Método	Nivel de seguridad	Ventajas	Desventajas
1. Contraseña tradicional	**Bajo – medio**	Es fácil de implementar, económica y conocida por los usuarios. No requiere dispositivos adicionales.	Puede ser robada mediante phishing, ataques de fuerza bruta o reutilización de contraseñas. Los usuarios suelen utilizar contraseñas débiles o repetidas.
2. Doble factor de autenticación (2FA)	**Bajo – medio**	Añade una segunda capa de seguridad. Aunque un atacante consiga la contraseña, todavía necesita el segundo factor. Puede utilizar aplicaciones de autenticación, códigos OTP, dispositivos físicos o biometría.	Puede ser más complejo para el usuario. Algunos métodos, como los códigos enviados por SMS, pueden ser vulnerables al phishing o al intercambio fraudulento de SIM.
3. Biometría	**Alto**	Utiliza características físicas como huella digital, rostro o iris. Es rápida y cómoda y, correctamente implementada, puede ser difícil de falsificar.	Requiere dispositivos compatibles. Existen preocupaciones de privacidad y, si los datos biométricos son comprometidos, no pueden cambiarse de la misma manera que una contraseña.
4. Tokens de seguridad	**Alto – muy alto**	Utilizan algo que el usuario posee, como un token físico o una llave de seguridad. Los tokens basados en criptografía de clave pública, como **FIDO2**, pueden ofrecer resistencia al phishing.	Pueden generar costos adicionales, requieren administración y el usuario puede perder o dañar el dispositivo.

¿Cuál método sería más adecuado para una entidad financiera?

Para una entidad financiera, lo más adecuado sería utilizar una autenticación multifactor (MFA) resistente al phishing, combinando diferentes factores. Una alternativa especialmente sólida son los tokens de seguridad o credenciales FIDO2/passkeys, que utilizan criptografía de clave pública y están diseñados para

resistir ataques de phishing. Esto es importante porque una institución financiera maneja información personal, cuentas bancarias y transacciones económicas. Una contraseña por sí sola no proporciona suficiente protección frente a ataques como phishing, fuerza bruta o robo de credenciales. OWASP recomienda utilizar MFA y señala que esta proporciona una defensa importante frente a ataques relacionados con contraseñas. Además, no toda MFA ofrece el mismo nivel de protección. Por ejemplo, los códigos enviados por SMS agregan una capa de seguridad, pero pueden seguir siendo vulnerables a phishing y otros ataques. FIDO Alliance señala que los autenticadores resistentes al phishing, basados en criptografía de clave pública, ayudan a solucionar estas vulnerabilidades.Por lo tanto, para una entidad financiera se recomienda una combinación como:

Contraseña + segundo factor resistente al phishing (FIDO2/passkey o token de seguridad), y biometría como mecanismo de verificación local cuando corresponda.

Actividad 5: Matriz de Control de Acceso **Objetivo:**

Aplicar conceptos de protección y control de acceso.

Modalidad: Individual

Caso: Una universidad posee los siguientes usuarios:

- Administrador
- Docente
- Estudiante

Y los siguientes recursos:

- Sistema académico
- Base de datos de notas
- Plataforma virtual

Tarea:

Diseñe una matriz de permisos utilizando:

- Lectura (L)
- Escritura (E)
- Modificación (M)

Ejemplo:

Usuario Sistema Académico Notas Plataforma / Administrador L,E,M L,E,M L,E,M

Matriz de Control de Acceso

Objetivo: Implementar mecanismos de protección y directivas de control de acceso (ISO/IEC 27032 cl. 9.2.3, NIST PR.AC-4, estructuras ACL y Listas de Capacidades).

1. Matriz de Permisos de Acceso (Lectura: L, Escritura: E, Modificación: M)

Usuario	Sistema Académico	Base de Datos de Notas	Plataforma Virtual
Administrador	L, E, M	L, E, M	L, E, M
Docente	L	L, E, M	L, E, M
Estudiante	L (o L, E en matrícula)	L	L, E

2. Justificación Técnica por Perfil (Mínimos Privilegios y Segregación de Funciones)

- **Administrador (L, E, M globales):** Requiere acceso total para administrar cuentas, ajustar el sistema académico, garantizar la continuidad y copias de seguridad de las evaluaciones, además de gestionar las aulas virtuales, sometiéndose a bitácoras de auditoría permanentes.
- **Docente (L en Sistema Académico | L, E, M en Calificaciones y Plataforma):** Consulta listas y horarios mediante lectura simple. Dispone de permisos completos de lectura, escritura y modificación sobre las notas y la plataforma educativa para consignar o corregir evaluaciones y publicar materiales didácticos durante el ciclo.
- **Estudiante (L en Sistema Académico y Registro de Notas | L, E en Plataforma):** Revisa asignaturas e historial académico en lectura (otorgando escritura únicamente al matricularse). En la base de notas solo posee consulta directa para resguardar la integridad del sistema. En el entorno virtual puede descargar archivos y presentar actividades, prescindiendo de facultades de modificación.

3. Desglose en Esquemas ACL y Listas de Capacidades (Sistemas Operativos)

- **Listas de Control de Acceso (ACL — enfocadas en recursos):** Asociadas a cada objeto, detallan los privilegios otorgados a cada perfil de usuario:

    - Sistema Académico → [(Administrador: L,E,M), (Docente: L), (Estudiante: L)]
    - Base de Datos de Notas → [(Administrador: L,E,M), (Docente: L,E,M), (Estudiante: L)]
    - Plataforma Virtual → [(Administrador: L,E,M), (Docente: L,E,M), (Estudiante: L,E)]
- **Listas de Capacidades (Listas C — enfocadas en sujetos):** Vinculadas a cada cuenta, establecen las acciones autorizadas sobre los recursos institucionales:
    - Administrador → [(Sistema Académico: L,E,M), (Notas: L,E,M), (Plataforma: L,E,M)]
    - Docente → [(Sistema Académico: L), (Notas: L,E,M), (Plataforma: L,E,M)
    - Estudiante → [(Sistema Académico: L), (Notas: L), (Plataforma: L,E)]

Actividad 6: Debate sobre Seguridad Informática

Objetivo: Analizar problemas reales relacionados con la seguridad de la información.

Modalidad: Grupal

Tema de debate:

"¿Las organizaciones deben monitorear permanentemente las actividades digitales de sus trabajadores para garantizar la seguridad de la información?"

Equipos:

- Equipo A: A favor.
- Equipo B: En contra.

Criterios de evaluación:

- Argumentación técnica.
- Uso de conceptos de seguridad.
- Capacidad crítica

Debate sobre seguridad informática

Tema: ¿Las organizaciones deben monitorear permanentemente las actividades digitales de sus trabajadores para garantizar la seguridad de la información?

Introducción

En la actualidad, las organizaciones utilizan sistemas informáticos, computadoras, correos electrónicos y redes digitales para almacenar y compartir información importante. Sin embargo, estos recursos están expuestos a amenazas como el robo de datos, los ataques informáticos y el acceso no autorizado.

Por esta razón, algunas organizaciones monitorean las actividades digitales de sus trabajadores para detectar comportamientos sospechosos y proteger la información, No obstante, esta práctica también genera preocupaciones relacionadas con la privacidad y los derechos de los empleados.
Ante esta situación, se plantea el siguiente debate: ¿las organizaciones deben monitorear permanentemente las actividades digitales de sus trabajadores para garantizar la seguridad de la información?

Argumentos del Equipo A: A favor

- **Argumento 1: Prevención de amenazas informáticas**

  Las organizaciones deben monitorear las actividades digitales porque esto permite detectar comportamientos sospechosos, como intentos de acceso no autorizado o descargas inusuales de archivos. Mediante los logs o registros de actividad, se pueden identificar eventos anormales y actuar antes de que ocurra un incidente grave. Esto contribuye a proteger la confidencialidad de la información.

- **Argumento 2: Protección de la información confidencial**

  El monitoreo ayuda a prevenir la fuga de datos de clientes, trabajadores y de la propia organización. Por ejemplo, si un usuario intenta enviar documentos confidenciales a una persona no autorizada, un sistema de seguridad puede generar una alerta. De esta manera, se protege la confidencialidad y se reduce el riesgo de divulgación de información sensible.

- **Argumento 3: Detección y respuesta ante incidentes**

  El monitoreo permite identificar posibles ataques informáticos y facilita la investigación de lo sucedido. Por ejemplo, varios intentos fallidos de inicio de sesión pueden indicar un intento de acceder ilegalmente a una cuenta. Mediante el monitoreo y el control de acceso, la organización puede investigar la actividad y tomar medidas para proteger la integridad y disponibilidad de sus sistemas.

- **Postura del Equipo A**

  Las organizaciones deben monitorear las actividades digitales porque esta práctica ayuda a prevenir amenazas, detectar incidentes y proteger la información. Sin embargo, debe realizarse con reglas claras y respetando la privacidad de los trabajadores.

Argumentos de Equipo B: En contra

- **Argumento 1: Afectación de la privacidad**

  El monitoreo permanente puede vulnerar la privacidad de los trabajadores si recopila información excesiva o que no está relacionada con la seguridad. Aunque las organizaciones deben proteger sus datos, también deben respetar los derechos de sus empleados y establecer límites claros sobre las actividades que pueden supervisar.

- **Argumento 2: Riesgo de uso indebido de la información**

  Los registros de actividad recopilados pueden contener información sensible y, si no están adecuadamente protegidos, podrían utilizarse de

manera inadecuada. Por ello, es importante aplicar controles de acceso para que solamente el personal autorizado pueda consultar estos registros y garantizar la confidencialidad de la información recopilada.

- **Argumento 3: Existen otras medidas de seguridad**

  Las organizaciones pueden proteger sus sistemas mediante la autenticación multifactor (MFA), el cifrado de datos, las copias de seguridad y la capacitación en ciberseguridad. Estas medidas ayudan a prevenir accesos no autorizados y a proteger la integridad y disponibilidad de la información sin necesidad de vigilar indiscriminadamente todas las actividades de los trabajadores.

- **Postura del Equipo B**

  Las organizaciones no deberían realizar un monitoreo permanente e indiscriminado, porque puede afectar la privacidad y generar desconfianza. La seguridad informática también puede garantizarse mediante controles técnicos y políticas de seguridad adecuadas.

Capacidad Crítica

Ambas posturas presentan argumentos importantes. Por un lado, el monitoreo puede ayudar a detectar amenazas, prevenir fugas de datos y proteger los sistemas informáticos. Por otro lado, una vigilancia excesiva puede afectar la privacidad de los trabajadores y permitir el uso indebido de la información recopilada. Desde un punto de vista crítico, el monitoreo por sí solo no garantiza la seguridad informática, ya que debe complementarse con medidas como el control de acceso, la autenticación multifactor, el cifrado y la capacitación de los empleados. Asimismo, la ausencia de vigilancia no significa que una organización esté desprotegida, siempre que cuente con controles de seguridad eficaces.

Por lo tanto, es necesario evaluar los riesgos de cada organización y establecer límites sobre qué información se recopila, con qué finalidad y quién puede acceder a ella. La seguridad debe mantenerse en equilibrio con la privacidad y los derechos de los trabajadores.

Conclusión

En conclusión, el monitoreo de las actividades digitales puede ser una herramienta útil para proteger la información y detectar amenazas informáticas, pero su aplicación permanente e indiscriminada puede generar problemas de privacidad. Por esta razón, las organizaciones deben implementar un monitoreo proporcional a los riesgos, transparente y limitado a una finalidad legítima. Además, deben complementarlo con controles de acceso, autenticación multifactor, cifrado y capacitación en seguridad informática. De esta manera, es posible proteger la confidencialidad, integridad y disponibilidad de la información sin descuidar la privacidad de los trabajadores.

Actividad 7: Caso Integrador

Objetivo: Integrar todos los conceptos desarrollados en la sesión.

Caso: Una empresa sufrió un incidente de seguridad:

- Un empleado compartió su contraseña.
- Se produjo acceso no autorizado.
- Se alteraron registros financieros.
- No existía autenticación multifacto.

Preguntas:

1. ¿Qué amenazas se materializaron?
2. ¿Qué objetivos de seguridad fueron afectados? 3. ¿Qué mecanismos de protección faltaban?
4. ¿Qué política de seguridad propondría?
5. ¿Qué modelo de control de acceso sería el más adecuado?

Producto esperado: Informe técnico de 2 a 3 páginas.

1. Introducción:

La seguridad informática es fundamental para proteger los sistemas, las redes y la información de una organización frente a amenazas que puedan comprometer su funcionamiento. Para ello, es necesario implementar políticas, procedimientos y mecanismos de protección que permitan prevenir accesos no autorizados, enviar a alteración de información y garantizar la confidencialidad, integridad y disponibilidad de los datos.

El presente informe técnico analiza el incidente de seguridad ocurrido en una empresa, en el cual un empleado compartió su contraseña, se produjo un acceso no autorizado y se alteraron registros financieros. Además, se identificó la ausencia de autenticación multifactor, lo que incrementó el riesgo de que una persona no autorizada accediera a los sistemas.

A partir de este caso, se identifican las amenazas materializadas, los objetivos de seguridad afectados, los mecanismos de protección que faltaban, las políticas que deberían implementarse y el modelo de control de acceso más adecuado para prevenir incidentes similares.

2. Análisis del incidente de seguridad:

El incidente evidencia deficiencias en la gestión de credenciales, en los mecanismos de autenticación y en la protección de la información financiera. El hecho de compartir una contraseña permitió que una persona distinta del usuario autorizado pudiera utilizar sus credenciales para ingresar al sistema. La falta de autenticación multifactor facilitó que el acceso dependiera únicamente de una contraseña.

Posteriormente, el acceso no autorizado permitió alterar registros financieros, comprometiendo la confiabilidad de la información empresarial. Esta situación puede generar pérdidas económicas, dificultades para realizar auditorías, incumplimientos normativos y daños a la reputación de la organización.

Por lo tanto, el incidente no debe considerarse únicamente un error individual, sino también una señal de que los controles técnicos y las políticas de seguridad de la empresa eran insuficientes.

3. Análisis del incidente de seguridad:

3.1. ¿Qué amenazas se materializaron?

En el caso se materializaron las siguientes amenazas:

- **Compromiso de credenciales:** el empleado compartió su contraseña, exponiendo sus datos de autenticación y facilitando que otra persona utilizara su identidad digital.
- **Acceso no autorizado:** una persona consiguió ingresar a los sistemas sin contar con la autorización correspondiente, aprovechando la vulnerabilidad asociada a las credenciales compartidas.
- **Alteración maliciosa de información:** los registros financieros fueron modificados sin autorización, poniendo en riesgo la exactitud y confiabilidad de los datos.
- **Suplantación de identidad:** al utilizar credenciales ajenas, el atacante pudo hacerse pasar por un usuario legítimo, dificultando la identificación del verdadero responsable de las acciones realizadas.
- **Ausencia de controles preventivos suficientes:** la falta de autenticación multifactor aumentó la posibilidad de que una contraseña comprometida fuera suficiente para ingresar al sistema.

Estas amenazas pudieron ocasionar consecuencias adicionales, como pérdidas económicas, fraude financiero, dificultades para detectar responsabilidades y pérdida de confianza en los sistemas de información.

3.2. ¿Qué objetivos de seguridad fueron afectados?

Los principales objetivos de seguridad afectados corresponden a los principios de la tríada CID: confidencialidad, integridad y disponibilidad.

a) Confidencialidad

Este principio garantiza que la información solo sea accesible para personas autorizadas. Se vio comprometido porque un tercero consiguió acceder a los sistemas mediante credenciales compartidas. Esto pudo permitir la consulta de información financiera confidencial sin autorización.

b) Integridad

La integridad consiste en mantener la exactitud, consistencia y confiabilidad de la información. Fue el objetivo más directamente afectado, ya que se alteraron registros financieros. Las modificaciones no autorizadas pueden provocar errores contables, decisiones empresariales incorrectas y posibles fraudes.

c) Disponibilidad

La disponibilidad garantiza que los sistemas y la información estén accesibles cuando los usuarios autorizados los necesiten. Aunque el caso no indica que los sistemas hayan dejado de funcionar, la alteración de registros puede dificultar el acceso a información confiable y requerir la suspensión temporal de los sistemas para investigar y corregir el incidente.

También se vio afectada la **autenticidad**, debido a que el uso de credenciales compartidas dificulta comprobar que las acciones realizadas corresponden realmente al usuario identificado.

3.3. ¿Qué mecanismos de protección faltaban?

La empresa debería implementar o fortalecer los siguientes mecanismos de protección:

- **Autenticación multifactor (MFA):** requiere dos o más factores de autenticación, por ejemplo, una contraseña y una aplicación de autenticación. Esto dificulta el acceso incluso cuando una contraseña ha sido comprometida.
- **Control de acceso basado en roles (RBAC):** limita los permisos de cada usuario según sus funciones y responsabilidades dentro de la empresa.
- **Registro y monitoreo de actividades:** permite registrar los accesos, las modificaciones realizadas y los intentos de inicio de sesión sospechosos, facilitando la detección de incidentes.

- **Copias de seguridad periódicas:** permiten recuperar los registros financieros originales o una versión confiable de los datos después de una alteración.
- **Gestión segura de contraseñas:** incluye el uso de contraseñas únicas, robustas y personales, así como procedimientos para cambiarlas o revocarlas cuando exista una sospecha de compromiso.
- **Principio de mínimo privilegio:** cada empleado debe contar únicamente con los permisos necesarios para realizar sus tareas.
- **Mecanismos de integridad y auditoría:** permiten detectar modificaciones indebidas y verificar la trazabilidad de los cambios efectuados en los registros financieros.

La combinación de estos mecanismos permitiría reducir la probabilidad de nuevos accesos no autorizados y mejorar la capacidad de respuesta de la organización.

3.4. ¿Qué política de seguridad propondría?

Se propone establecer una **Política de Gestión de Identidades, Autenticación y Protección de la Información Financiera**, de cumplimiento obligatorio para todos los empleados y colaboradores.

Esta política tendría como objetivo prevenir el uso indebido de las credenciales, restringir el acceso a información sensible y garantizar la integridad de los registros financieros.

Sus principales disposiciones serían las siguientes:

1. **Uso personal de credenciales:** queda prohibido compartir contraseñas, códigos de autenticación o cualquier otro medio de acceso.
2. **Autenticación multifactor obligatoria:** todos los usuarios deberán utilizar MFA para acceder a los sistemas financieros y demás recursos críticos.
3. **Asignación de permisos:** los accesos se otorgarán según el puesto y las funciones de cada trabajador, aplicando el principio de mínimo privilegio.
4. **Supervisión de actividades:** las acciones realizadas en los sistemas financieros deberán quedar registradas y ser revisadas periódicamente.
5. **Protección de los registros:** las modificaciones de información financiera deberán estar autorizadas, identificadas y respaldadas por registros de auditoría.
6. **Capacitación del personal:** se realizarán capacitaciones periódicas

sobre contraseñas seguras, ingeniería social, amenazas informáticas y reporte de incidentes.

7. **Respuesta ante incidentes:** cuando se detecte un acceso sospechoso, se deberán revocar o restablecer las credenciales comprometidas, restringir las sesiones afectadas, preservar las evidencias y recuperar los datos confiables cuando corresponda.

La política deberá ser aprobada por la dirección de la empresa, comunicada a todos los trabajadores y revisada periódicamente. Asimismo, se deberán definir responsables de su cumplimiento y medidas correctivas ante las infracciones, de acuerdo con la normativa aplicable y las disposiciones laborales vigentes.

3.5. ¿Qué modelo de control de acceso sería el más adecuado?

El modelo más adecuado para este caso es el **control de acceso basado en roles (RBAC, Role-Based Access Control)**, complementado con el principio de mínimo privilegio y la autenticación multifactor.

RBAC asigna permisos de acceso según los roles que desempeñan los usuarios dentro de la organización. Por ejemplo, un empleado del área contable podría consultar y registrar operaciones financieras autorizadas, mientras que un auditor tendría permisos de revisión y un administrador del sistema gestionaría los accesos técnicos, sin que esto implique automáticamente autorización para modificar transacciones contables.

Este modelo resulta apropiado porque permite administrar los permisos de manera organizada, aplicar restricciones según las responsabilidades laborales y reducir el riesgo de que un empleado o atacante obtenga acceso excesivo a información crítica.

Además, se recomienda implementar la **separación de funciones**, de modo que las operaciones financieras sensibles requieran controles adicionales, como una segunda aprobación para determinadas modificaciones. Así, una sola cuenta no debería tener capacidad ilimitada para crear, modificar y aprobar transacciones sin supervisión.

Es importante señalar que RBAC no reemplaza la autenticación: el modelo determina qué recursos puede utilizar un usuario, mientras que la autenticación multifactor ayuda a comprobar su identidad. Ambos controles deben funcionar conjuntamente.

4. Recomendaciones de mejora

Para fortalecer la seguridad informática de la empresa, se recomienda aplicar las siguientes acciones:

- **Acción inmediata:** bloquear o restablecer las credenciales comprometidas, revocar las sesiones activas sospechosas e investigar

el alcance del acceso no autorizado.

- **Recuperación de la información:** comparar los registros financieros afectados con copias de seguridad y evidencias de auditoría para identificar y corregir las modificaciones indebidas.
- **Implementación de controles:** habilitar MFA, establecer permisos por roles y activar registros de auditoría que permitan rastrear las actividades realizadas.
- **Prevención:** capacitar al personal sobre el uso responsable de las credenciales y las consecuencias de compartirlas.
- **Evaluación continua:** realizar auditorías periódicas, revisar los permisos asignados y probar los procedimientos de recuperación de información.

Estas acciones deben ejecutarse de forma coordinada, priorizando la contención del incidente y la preservación de evidencias antes de realizar cambios que puedan dificultar la investigación.

5. Conclusiones

El incidente analizado demuestra que compartir contraseñas y carecer de mecanismos de autenticación adicionales puede facilitar accesos no autorizados y comprometer información crítica para una organización.

Las amenazas materializadas fueron el compromiso de credenciales, el acceso no autorizado, la suplantación de identidad y la alteración de registros financieros. Como consecuencia, se afectaron principalmente la confidencialidad, la integridad y la autenticidad de la información, con posibles repercusiones sobre su disponibilidad.

Para prevenir nuevos incidentes, es necesario implementar autenticación multifactor, control de acceso basado en roles, registros de auditoría, copias de seguridad y políticas claras para la gestión de credenciales. La aplicación conjunta de estas medidas, acompañada de capacitación y supervisión continua, permitirá reducir los riesgos, mejorar la trazabilidad de las operaciones y fortalecer la seguridad de los sistemas empresariales.

En conclusión, la seguridad informática requiere tanto soluciones tecnológicas como el compromiso de los trabajadores y de la dirección de la empresa. Una política de seguridad bien definida y aplicada de manera constante constituye una herramienta esencial para proteger los activos de información y garantizar la confiabilidad de las operaciones financieras.

6. Referencias bibliográficas

- National Institute of Standards and Technology (NIST). (2020). *Security and Privacy Controls for Information Systems and Organizations (SP*

800-53 Rev. 5). https://doi.org/10.6028/NIST.SP.800-53r5
- National Institute of Standards and Technology (NIST). (2017). *Digital Identity Guidelines: Authentication and Lifecycle Management (SP 800-63B).* https://doi.org/10.6028/NIST.SP.800-63b
- National Institute of Standards and Technology (NIST). (2024). *The NIST Cybersecurity Framework (CSF) 2.0.* https://doi.org/10.6028/NIST.CSWP.29